

The Money AI Is Allowed to Move

Fintech's Next Decade

For a decade, the amount of money AI has been allowed to move in finance has been zero.

That number is now leaving zero — and almost nobody is pricing it in.

75%

of firms already use AI
but only 17% of use cases are
foundation models^[4]

2%

of use cases are fully autonomous
every other one keeps a human in
the loop^[4]

\$1.9T

one company's annual payment
volume
a yardstick for execution rights^[16]

≈ 0

money entrusted to AI today with
no human review
the variable this book tracks

What this book argues

Almost every public conversation about AI in finance circles one question: when will models outperform human analysts? It is the wrong question. Finance has never been short of clever judgment. What it lacks is **the authority to turn judgment into action**.

So this book tracks a single line: **how much money an AI system is allowed to move without a human reviewing it**. I call it the **trusted-amount ceiling**. At most institutions today it is zero. But it is leaving zero, and it moves in steps: each step is unlocked by a specific, observable set of conditions.

This line is more worth watching than any capability curve. It is **verifiable** — tender documents and incident disclosures will spell it out. It **shapes revenue models** — systems that can move money are priced on outcomes, systems that cannot are priced per seat. And it is **non-linear**: unlocking each step needs governance, liability and insurance to fall into place together, so the line stalls for years and then jumps.

The book has five chapters: establish the trend line, project the end state, take apart four fronts of competition, examine how regulators enter, and close with six falsifiable bets and a tracking list.

Method
I do not forecast model capability; I project the boundary of authority. Every forward-looking passage states its trigger and its falsification condition, so readers can update it each quarter as new facts arrive.

Evidence hierarchy
Regulatory filings and audited annual reports come first. Company-reported figures confirm direction only and never drive a conclusion. Media valuations are not used at all. Full sources are in the appendix.

Disclosure
Nothing here is investment advice. No non-public information is used; every company fact comes from public disclosure.

Contents · Five chapters and appendices

Part	Title	The question it answers	Page
Preface	A Number That Has Always Been Zero	Why "how capable is the model" is the wrong question, and "how much money may it move" is not	03
Ch. 1	The Five-Rung Ladder to Closed Loops	The five levels of the trusted-amount ceiling, what unlocks each, and where we stand now	05
Ch. 2	From Executor to Financial Operating System	What settlement, identity and pricing look like once machines become customers	12
Ch. 3a	Fighting for the Rails	Why execution rights are the one asset model progress cannot dilute	17
Ch. 3b	Locking the Ledger	Data rights, permissions and supply-chain concentration: misused permissions are more dangerous than bad judgment	21
Ch. 3c	The Trustworthiness Problem	How to let a system you don't fully understand move money — a product problem	24
Ch. 3d	The Standards War	Whoever sets agent-payment protocols, liability splits and cross-border recognition collects the long-term rent	28
Ch. 4	How Regulation Arrives	Not prohibition but governance written into market access — and what that means for products	32
Ch. 5	Six Bets	If you are building products in 2026, what exactly to bet on, and when to concede	35
Appendix	Tracking List and Sources	Signals to watch, definitions, 24 sources and the evidence-discount rules	37

How to read this book

If you have ten minutes: read the preface, the ladder figure in Chapter 1 (page 06) and the six bets in Chapter 5. Together they hold every conclusion.

If you are a product manager: Chapters 3c and 4 will be the most useful. They cover what goes into your PRD tomorrow — limits, circuit breakers, audit events and exit mechanisms.

If you want to prove me wrong: every chapter ends with "Where I might be wrong," listing the evidence most likely to overturn it. Start there.

On the title
"Allowed" is the book's entire position. What decides fintech's next decade is not the ceiling of capability but the boundary of authority — two things public debate routinely conflates.

A number that has always been zero

In 2024 the Bank of England and the Financial Conduct Authority ran an industry-wide survey: 75% of responding financial firms were already using AI, and another 10% planned to within three years. The figure travelled widely, usually as proof that finance has "fully embraced AI."^[4]

The same survey contains three other numbers that almost nobody quotes. First, foundation models account for only about 17% of use cases — three-quarters of "AI applications" are still the predictive models of a decade ago. Second, 55% of use cases involve some degree of automated decision-making, but **only 2% are fully autonomous**. Third, firms rate 62% of their use cases as low materiality and only 16% as high.^[4]

Put the three together and the conclusion is the opposite of "full embrace": AI has spread through the **periphery** of finance but has not entered its **core**. It writes marketing copy, answers customer questions and helps engineers code. It does not approve loans, place orders, move funds or sign tax filings.

This is not because the models aren't smart enough. In many regulated activities, model judgment already beats a junior employee. The real obstacle lies elsewhere: **nobody is willing to answer for a system that can't be explained, traced or made to pay for its mistakes.**

So the variable worth tracking is not capability but authority. Specifically, this number:

How much money is an AI system allowed to move without a human reviewing each transaction?

At the vast majority of financial institutions today, the answer is zero. Not "small" — **zero**. Any action that touches funds, credit or a regulatory filing needs a natural person to sign off somewhere, even when the signature is a formality.

Zero is a peculiar number. It means the curve hasn't started, so nobody models it and nobody prices it. The market still values AI-in-finance companies on "how much labor they save" — pricing third-generation products as if they were second-generation ones.

But zero is breaking. Stripe says its adaptive acceptance recovered a record of roughly \$6 billion in falsely declined legitimate transactions in 2024, up 60% year on year, and Radar claims an average 32% reduction in fraud for its users.^{[16][17][18]} Intuit reports that more than 3 million customers have let AI agents do work for them, with historical repeat usage above 85%.^{[19][20]} Ant Group has launched a payments MCP server and an AI wallet, plainly aimed at plugging agents into money movement.^{[14][24]}

These are all still small-value, high-frequency, reversible actions. What they share is this: **the system made a decision without anyone looking at the individual case, and that decision directly changed where money went.** Zero is no longer zero.

The three examples come from very different companies: a payments network, a tax-and-accounting software firm and a super-app. They share no model vendor and no jurisdiction. **What they do share is an execution interface.** Capability spreads everywhere; authority does not. Authority flows only to those who already hold the interface and the capacity to bear liability.

75%

Already using AI

UK regulators' survey, 2024, 118 firms. It looks like the finish line but is really the starting line — it counts "has used," not "has entrusted."^[4]

17%

Share that are foundation models

Three-quarters of use cases are still traditional predictive models. Generative AI has gone nowhere near as deep as the narrative suggests.^[4]

2%

Fully autonomous use cases

Another 24% are semi-autonomous: they make some decisions alone, but critical or ambiguous calls are designed to go to a human.^[4]

Why "zero" matters so much

In self-driving the equivalent variable is hands-off time; in industrial automation, unattended run time. In finance it is the trusted amount. Every curve of this kind hugs the floor for years, then climbs in steps.

Shifts already under way

Automatic recovery of false declines, automatic matching of bank feeds, agent payment tokens — in all three the system changes where money flows, just in small, reversible amounts.

What the three have in common

None leads on models; all hold execution interfaces. This is the book's core observation.

Nobody is pricing this in

The World Economic Forum estimates that AI spending in financial services will grow from about \$35 billion in 2023 to about \$97 billion in 2027.^[5] The figure is often used to argue the market is large. But if you believe the trusted amount will leave zero, the forecast is **badly understated** — because it counts money spent *on* AI, not money that passes *through* AI.

The two differ by orders of magnitude. One payments company processes \$1.9 trillion a year.^[16] If even one ten-thousandth of those decisions shifted from people to systems, the commercial value would not be a software licence fee but a **take rate** on that flow. Software budgets and transaction take rates sit three to four orders of magnitude apart.

That is what I mean by "nobody is pricing it in." Today's market is valuing a software market. If this trend line holds, what actually forms is an **infrastructure market** — one that, like clearing houses, card networks and exchanges, charges by volume rather than by seat.

Three premises

Premise one: model capability will keep commoditizing. I do not assume any company achieves a durable lead in models. On the contrary, the whole argument rests on models becoming interchangeable inputs. If that is wrong, the book's conclusions weaken considerably.

Premise two: regulation tightens rather than loosens. China's 32 guiding opinions of June 2026, the US Treasury's FS AI RMF of February 2026 (with 230 control objectives), and the EU's AI Act and DORA all point the same way: risk-tiered, full-lifecycle, traceable.^{[10][11][12][13]} I assume that direction holds.

Premise three: liability does not disappear. However the technology changes, finance must ultimately answer "who pays when it goes wrong?" Any product design that sidesteps that question will be stopped at the door of the core process.

\$35B→\$97B

Global AI spend in finance

WEF: 2023 actual → 2027 forecast. This is money spent on AI.^[5]

\$1.9T

One company's payment volume

This is money AI might handle. The two measures differ by more than three orders of magnitude.^[16]

If premise one is wrong

If one company builds a durable, hard-to-copy lead in finance-specific models, models are no longer interchangeable inputs and this book overvalues the control points. This is where I think I am most likely to be wrong.

If premise two is wrong

If major markets loosen regulation markedly, the premium on early execution rights and governance capability is diluted, and speed beats compliance. Chapter 4 explores that scenario.

Figure 0.1 · Where two narratives diverge: what the market is actually pricing

View	Variable tracked	Implied market structure	How it charges
Mainstream	Model capability, parameters, benchmark scores	A software market priced on headcount replaced	Seats, subscriptions, API calls
This book	Trusted-amount ceiling, depth of authority	An infrastructure market priced on volume and liability	Take rates, outcome shares, governance subscriptions
The fork	If AI can only advise and never execute, the mainstream narrative is right. Once it may move money without review, the second narrative operates at a different order of magnitude.		

This isn't about which view is more optimistic. For most of today's AI application companies the second narrative is actually more pessimistic — it means value will concentrate in the few institutions that hold execution rights and the capacity to bear liability.

Where I might be wrong

The strongest objection: the boundary of authority in finance is neither a technical nor a governance problem but one of **institutional inertia**, and it may not move for decades. Finance has historically adopted new technology on a timescale of decades. If this curve is still flat on zero by 2030, my timeline is wrong across the board, even if the direction is not.

Falsification condition

If by end-2029 no category of financial action in any major market is broadly allowed to execute without per-transaction human review — not even small, reversible ones — the ladder extrapolation in Chapter 1 has failed.

CHAPTER ONE

The Five-Rung Ladder to Closed Loops

Advances in model capability don't translate directly into change in finance, because a gate stands in between: authority. This chapter quantifies the gate itself — five levels, each unlocked by a specific set of conditions — and asks which rung we are actually standing on.

THE CLAIM

By 2030, at least one category of high-frequency, reversible financial action will be broadly allowed to execute without per-transaction human review in major markets. No model breakthrough is required — only governance, insurance and a clear allocation of liability, all arriving together.

1.1

Making "trusted" countable

1.2

What unlocks each rung

1.3

Where we stand

1.4

Why it moves in steps

1.5

Extrapolation and timeline

1.1 Making "trusted" countable

Self-driving levels are useful not because they describe the technology precisely, but because they **translate a continuous technical problem into a discrete liability problem**. The real difference between L2 and L3 isn't how well the car drives; it is who is responsible in a crash — the driver at L2, the system provider at L3. The industry was stuck between those two levels for years, and perception algorithms were never what held it back.

Finance needs the same kind of scale, and has better reason to: every action in finance already carries a clear owner and audit requirements. Yet no widely accepted framework exists, so the debate stays stuck on unfalsifiable questions like "can AI be a financial adviser?"

I propose a five-level framework. It is defined not by model capability but by three things: **whether the system can reach conclusions on its own, whether it can act on its own, and who bears the consequences when it does**.

L0 Observe. The system only reads and organizes; it produces no business conclusions. Report generation, data retrieval and document classification live here. Most first-year "AI transformation" results stop at this level.

L1 Advise. The system produces conclusions, but a human must accept each one. This was the standard shape of generative copilots from 2023 to 2025. Its commercial problem isn't that it doesn't work — it's that value can't be attributed. A person still makes the final call, so you can't prove the improvement came from AI.

L2 Bounded execution. The system acts automatically within preset limits, allowlists and scenario boundaries; humans spot-check afterwards. **This is the rung where zero breaks:** from here on, the system's output directly changes where money goes. Today's most advanced products are early in this level.

L3 Conditional autonomy. The system executes by default and escalates only exceptions. The institution formally accepts that routine decisions belong to the system and holds reserves or insurance against them. This level has not yet appeared widely in regulated core financial processes.

L4 Full autonomy. No preset limits; systems negotiate and execute across institutions. It won't be mainstream within the foreseeable decade, but it shapes the end state, so it earns its own discussion (Chapter 2).

How levels are defined

Not by how strong the model is, but by three observable facts: can it reach conclusions alone, can it act alone, and who bears the consequences. All three leave evidence in contracts and incident disclosures.

Why not an "automation rate"

An automation rate lumps L0 report generation together with L2 automatic loan disbursement. Their commercial and risk profiles differ by orders of magnitude; a metric that blends them means nothing.

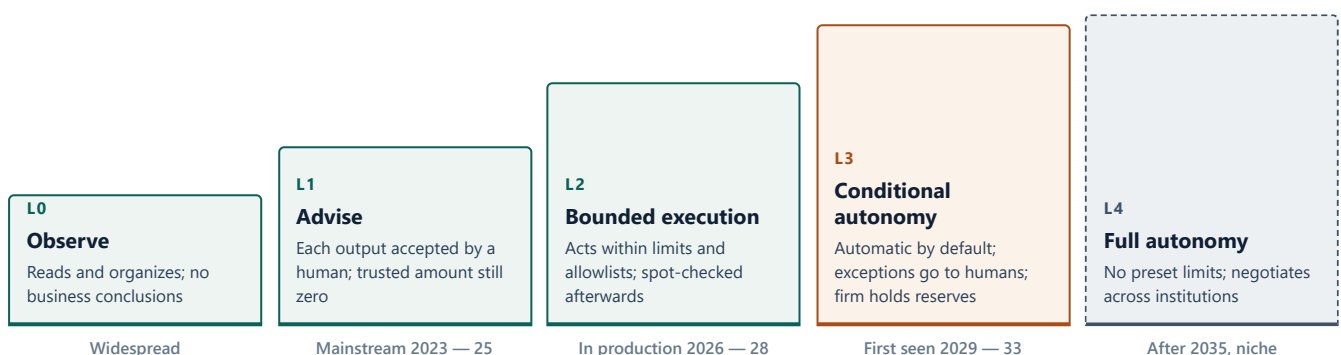
The L1 commercial trap

Copilots are the easiest products to build and the hardest to renew. A human makes the final decision, so ROI can't be attributed, and you negotiate every renewal from weakness. This is a structural flaw of second-generation products, not an execution problem.

L2 is the watershed

It is the first level at which outcome-based pricing makes logical sense — the system's action now has a direct causal link to the business result.

Figure 1.1 · The five-rung ladder of the trusted-amount ceiling: each rung unlocks a business model



Bar height shows the relative magnitude of the trusted-amount ceiling on a non-linear scale; it conveys the step pattern, not actual values. Dates are this book's projections; triggers and falsification conditions are in Section 1.5.

1.2 What unlocks each rung

On technology alone, getting from L1 to L2 needs almost nothing new: wire the model's output to an API and you're done. Plenty of teams can demo it in a week. But what separates the demo from production isn't a technical gap. It is three sets of prerequisites, all missing at once.

Technical prerequisites are usually met first, and are the easiest to mistake for the only ones: confidence can be estimated, actions can be rolled back, and everything leaves a trail. None of this is hard; many teams simply haven't done it, because a demo doesn't need it.

Governance prerequisites are the real bottleneck. They require a jointly agreed evaluation set with a human baseline, tiered authorization, circuit breakers and fallback paths, a complete chain of audit events, and proof that the vendor can be replaced. **Not one of these can be solved by model capability.** They are all problems of product and organizational design.

Commercial prerequisites are the most often overlooked: there must be a buyer willing to pay for outcomes and empowered to transfer some of the liability. When the buyer is the IT department, procurement inevitably falls back on "how many heads did it save." Only when the buyer owns the business line is there pricing room for products above L2.

A demo in a week, not in production after two years

This is the shared experience of almost every AI project in finance. A demo needs only the technical prerequisites; production needs all three sets at once.

Governance isn't compliance's job

Evaluation sets, tiered authorization, circuit breakers and audit events are all product features. Leaving them for compliance to "add later" pushes launch back a year.

Figure 1.2 · What unlocks each rung: technical, governance and commercial prerequisites

Step	Technical	Governance	Commercial	Status
L0 → L1	Usable general models and retrieval	Clear data rights; outputs logged	Someone will pay for productivity tools	Met; widely deployed
L1 → L2	Estimable confidence; reversible actions	Gold-standard eval set, human baseline, tiered authorization, circuit breakers and fallback, audit event chain	Buyer shifts from IT to business owner	The current bottleneck
L2 → L3	Long-run stability evidence; drift monitoring	Institutionalized liability, incident disclosure, independent third-party validation	Insurance or reserve arrangements mature	Scattered pilots; not standardized
L3 → L4	Cross-system mutual recognition of identity and permissions	Inter-institution protocols, chargeback and compensation rules, dispute arbitration	Volume-based clearing arrangements exist	Standards unsettled; see Ch. 3d

How to read it: the three prerequisites in each row are joined by AND — if any one is missing, the step doesn't happen. The industry as a whole is stuck on the governance column of the second row, not the technical one.

The table explains a counter-intuitive fact: **three years of enormous progress in model capability have barely moved the boundary of authority in finance.** All the progress landed in the technical column; the bottleneck was always in governance. It also explains why some technically unremarkable companies closed the loop first.

Stripe's Radar may not lead on models, but it has network-scale outcome labels, an existing dispute process and a money-movement interface — all three prerequisites come built in.^{[17][18]} Intuit builds CPAs and tax experts into the product, in effect **buying the liability prerequisite with human backstops**, which lets its agents enter a high-liability task like tax filing.^{[19][20]}

This leads to a corollary that isn't kind to startups: of the three prerequisites, only the technical one can be achieved by a team on its own. The other two must be built together with the buyer. **Products above L2 cannot be made in a lab.**

That is what makes a "design partner" special. What you need isn't feature feedback but an organization willing to share your first incident with you.

The key corollary

The next winners won't be the companies with the best models but the ones that assemble all three prerequisites first. This frames the analysis in every chapter that follows.

Seen from the other side

If you are building a pure model or pure application-layer product, this table is bad news: your technical edge is depreciating, and the two columns you lack can't be closed by working weekends.

1.3 Where we stand

Place six major areas of finance on this framework and the picture is strikingly uneven. It says more about where the industry really is than any overall adoption rate.

Only one area runs steadily at L2: **payment risk**. It approves or blocks transactions automatically; humans only spot-check afterwards and handle disputes. The reason is easy to see — the area meets all three prerequisites by nature: outcome labels flow back in real time, actions are reversible, a dispute process already exists, and the buyer is the business itself.

Customer service and operations are moving from L1 to L2. The boundary is "may change state but not move money": the system can update an address, cancel an order or reship, but refunds are still capped.

Tax, accounting and reconciliation is the next most likely area to cross into L2: answers are objectively right or wrong, systems of record exist, and the industry has a tradition of expert backstops.^{[19][20]}

Research and wealth management sits at L1 and won't move soon. The obstacle isn't technology but suitability obligations and mis-selling liability, which make "unreviewed advice" hard to sustain in law.

Credit and pricing is also stuck at L1: explainability and fairness reviews require every feature to be justified, which rules out a large class of end-to-end approaches.

Trading and treasury is the most conservative cell. It has sandboxes, limits and layered reviews, and its tail risk dwarfs the others — a failure doesn't lose one order; it can set off a market-wide chain reaction.^[7]

Look at the six together and a clear rule emerges: **how far an area can go depends on how quickly its errors are discovered, and whether they can be undone once they are**. A payment-risk error surfaces in seconds and can be reversed in minutes; bad investment advice may take months to show and can't be undone. This rule explains today's distribution better than "high risk versus low risk."

It also gives a practical filter. When assessing any AI opportunity in finance, ask three questions first: How quickly is an error discovered? Can it be undone? Who bears the cost of undoing it? If all three answers are clear, the area has a shot at L2. If any one is unclear, it will stay at the advice layer.

Note that the filter has nothing to do with how important an area is. Fraud prevention is not easier than financial advice — quite the reverse — but its error structure is friendlier. **Choosing an area is not about difficulty; it's about how observable the errors are.**

The only area stable at L2

Payment risk. It is the reference case for the whole trend line — not because it's the hardest, but because it has all three prerequisites by nature.

"May change state, not move money"

This is the real boundary of most controlled execution agents today. It is both a product boundary and a liability boundary.

Why research is stuck

Not because the model answers badly, but because suitability and mis-selling rules require an accountable natural person. Until the rules change, the level won't.

The special nature of systemic risk

The FSB flags herding risk specifically: when many institutions use similar models, individual rationality can become collective resonance. This is the root reason trading is more conservative than every other area.^[7]

This chart is easy to misread: a cell further right doesn't mean a bigger opportunity. Quite the opposite — **areas stuck at L1 with no near-term path forward are the least worth investing in**. You'll exhaust yourself building a product whose value can never be attributed and whose price can therefore never rise. The real opportunity lies in the cells that are "L1 now, reachable L2 within three years."

A second observation: the three blocked areas are stuck for different reasons — research because **the accountable party must be a natural person**, credit because **decisions must be explainable**, trading because **the scale of failure can't be contained**. They won't unlock together, and lumping them together as "high-risk areas" misses each one's real trigger.

Don't group by "risk level"
The three blocked areas are stuck for different reasons, so they won't unlock at the same time or because of the same event.

The cells least worth investing in
Areas at L1 that won't move for three years. You'll build a product that can never be attributed and so never repriced.

Figure 1.3 · Six areas: current level and level reachable within three years

Area	L0	L1	L2	L3	L4	The one thing holding it back
Payment risk	Passed	Passed	Now	≤ 3 yrs	—	No standard yet for agent authorization and chargeback liability
Service & operations	Passed	Now	≤ 3 yrs	—	—	Overreach and inconsistent definitions
Tax & reconciliation	Passed	Now	≤ 3 yrs	—	—	Dirty data and fragmented systems
Research & wealth	Passed	Now	Blocked	—	—	Suitability obligations and mis-selling liability
Credit & pricing	Passed	Now	Blocked	—	—	Explainability and fairness review
Trading & treasury	Passed	Now	Blocked	—	—	Tail risk and herding across markets

Levels are this book's research judgments, based on public product materials and regulatory documents. "≤ 3 yrs" means reachable if the triggers are met, not that it will necessarily happen.

Figure 1.3b · What each blocked area needs in order to unlock

Area	The real blocker	What has to happen	Who can drive it	Our view
Research & wealth	Suitability rules require an accountable natural person	A standard liability split for "machine advice + licensed human review," or regulators clearly defining an exemption	Securities regulators and self-regulatory bodies	Little real change before 2030
Credit & pricing	Every feature must be explainable and pass fairness review	Reviewers formally accept explainability methods, or a two-track norm forms: traditional models price, LLMs prepare supporting material	Banking supervisors and consumer-protection agencies	Partial easing before full opening
Trading & treasury	Failures can't be contained; herding risk	Model-diversity requirements, concentration monitoring and linked circuit breakers	Macroprudential authorities and market infrastructure	Will persist under limits and scope restrictions

Each row has an entirely different driver, so the three unlock paths are independent. For product teams: don't expect a single regulatory breakthrough to open all three doors.^[7] [10][11][12]

The table carries one more message: **blocked doesn't mean no business**. Research, credit and trading can still support large businesses at L1 — but value has to be priced on productivity, not outcomes. Confusing the two pricing logics is the most common commercial mistake in all three areas.

Blocked ≠ no business
You just have to price on productivity, not outcomes. Pick the wrong pricing logic and no product, however good, will close the deal.

1.4 Why it moves in steps, not gradually

If the trusted amount rose along a smooth curve, the industry would reshuffle gently: every company would climb at its own pace and first-mover advantage would be limited. But I don't think the curve is smooth. It hugs the floor for a long time, then jumps up in steps. There are three reasons, none of them technical.

First, liability is discrete. Law and contracts don't accept "the system is 70% responsible." Liability sits either with the human or with the system provider. So every step up must come with an explicit **transfer of liability** — and liability doesn't transfer gradually. It takes a specific date and a specific clause.

Second, insurance is discrete. No actuarial basis, no policy; no policy, and no institution dares hand over routine decisions. Actuaries need incident data, and incident data requires someone to have tried without insurance first. It's a classic cold-start problem: **the market either stalls indefinitely or suddenly opens at a tipping point.**

Third, audit is discrete. Auditors can't issue a "partially compliant" opinion. Either a system can fully reconstruct its decision chain or it can't. Full reconstruction needs an entire infrastructure — an event bus, tamper-proof logs, versioned models and prompts, permission snapshots. None of it is any use until it is finished, and all of it is usable the moment it is.

Finance has been through exactly this pattern before. The card industry's migration from magnetic stripe to chip used technology that had long been mature; the real migration came **after the liability shift took effect** — the rule that if a merchant hadn't upgraded its terminals, it bore the loss from counterfeit-card fraud. The technology was ready for years; behavior changed within a year or two either side of the rule.

I believe every step up for AI in finance will happen the same way: a long stretch of technical preparation and scattered pilots, then a regulatory or industry-level allocation of liability, then rapid, almost forced adoption. **So what's worth watching isn't model launches but changes in the wording of liability clauses.**

Three discontinuities

Liability, insurance, audit. None takes continuous values, so stacked together they are bound to produce steps.

Insurance's cold-start loop

No incident data → no actuarial model → no policy → nobody dares use it → no incident data. Breaking the loop usually takes a big player willing to self-insure, or a regulatory push.

A historical parallel: the card liability shift

Chip technology was mature for years, yet adoption clustered around the date the liability rule took effect. Rules changed behavior; technical availability did not.

What to watch

Not benchmark scores, but how tender documents, insurance terms and regulatory Q&As word "who bears the loss." Changes in those texts lead market behavior.

Figure 1.4 · Anatomy of a step change: four events that must happen in order

Stage	What happens	Observable signals	Typical duration
1 Technical readiness	Capability available, demos mature, scattered pilots	Product launches, papers, demo videos	1 – 3 years; long under way
2 Evidence builds	A few firms take the risk themselves and generate incident data and baselines	Company-reported efficiency data; industry evaluation sets appear	2 – 4 years; where we are now
3 Liability shifts	Regulatory or industry rules make clear who bears the loss	Changing wording in tenders, insurance products and regulatory Q&As	Concentrated within 1 – 2 years
4 Rapid adoption	Those who don't upgrade start bearing the cost; migration is forced	Procurement standards converge; vendors reshuffle fast	1 – 3 years; irreversible

In this book's view, the L1 → L2 step is late in stage 2. Stage-3 signals (insurance products and liability clauses) are the window most worth positioning for early.

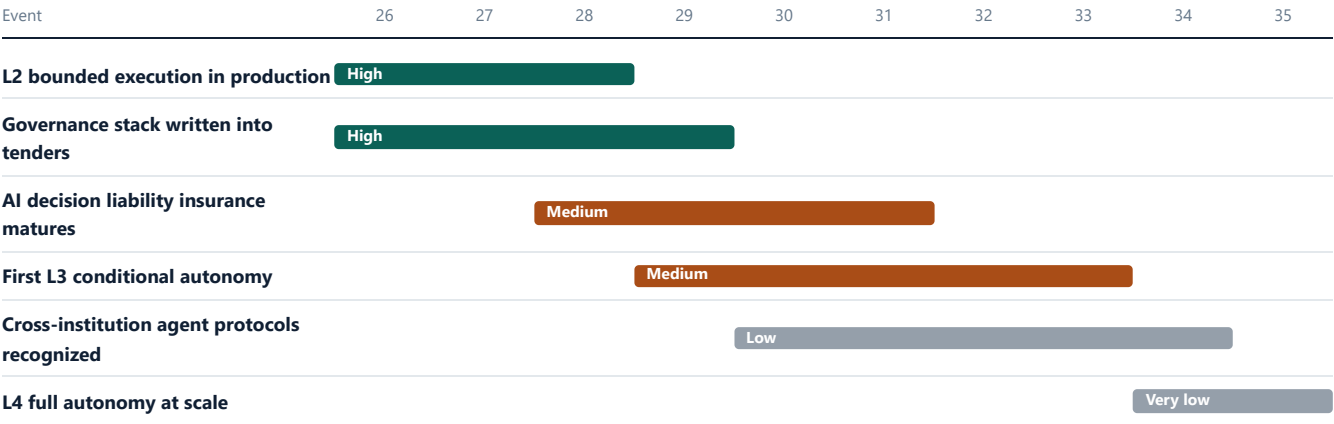
1.5 Extrapolation and timeline

Taken together, the four sections above yield a timeline. It isn't a forecast but a **conditional projection**: each item carries triggers and falsification conditions, and the judgment should change when those conditions are observed — not because a date has passed.

The core call: **the L1 → L2 step is late in evidence-building, and the liability shift is most likely to cluster between 2027 and 2029**. Signals are moving on three fronts at once — regulators requiring full-lifecycle records, large institutions writing exit mechanisms into tenders, and the first commercial arrangements to compensate for AI decisions.

Conditional, not predictive
Update on conditions, not on the calendar. If triggers are slow to appear, the right response is to push the timeline out, not to abandon the framework.

Figure 1.5 · Projected timeline, 2026 — 2035



Bars mark the most likely window, not a firm prediction. Confidence reflects how strongly current public evidence supports each item; colors follow the confidence scale used throughout the book.

Three windows to watch

2026 — 2027: the contract window. Once "ownership of evaluation sets," "audit retention periods" and "exit and data return" appear as standalone clauses in tenders, the governance stack has gone from nice-to-have to mandatory.

2027 — 2029: the insurance window. Watch for a standalone line of cover for AI decision errors, and the basis on which it is priced. Once policies are available, the economics of L2 → L3 work immediately.

2029 — 2032: the protocol window. Watch whether agent-payment authorization, chargebacks and cross-platform recognition converge on a standard — the battle that decides how the end state is divided. See Chapter 3d.

Where I might be wrong

The strongest objection: **the liability shift may never happen**. Finance could simply keep AI at L1 forever — smaller gains, but zero institutional cost. If the industry settles into that conservative equilibrium, only L0 and L1 of this ladder matter.

A second, more technical objection: the trusted amount is highly scenario-dependent. The same system may be allowed amounts orders of magnitude apart for refunds and for loan disbursement. Hence the per-area table in Section 1.3.

The third objection points the other way: the step could come **sooner**. If a large institution chooses to self-insure and absorb the first few incidents, it bypasses the insurance cold start alone, pulling the medium-confidence windows forward by about two years.

What to do in the contract window
Build those three items into the product now and price them separately. It's an order of magnitude cheaper than retrofitting them. Chapter 4 expands on this.

This chapter's falsification condition
If by end-2029 no category of financial action in a major market is broadly allowed to execute without per-transaction review, or no liability insurance product for AI decisions has appeared, the ladder extrapolation has failed.

Don't underestimate the conservative equilibrium
Finance has repeatedly chosen "the technology works, but the institution won't adopt it." If that happens again, value stays in labor substitution rather than flowing to execution rights.

CHAPTER TWO

From Executor to Financial Operating System

Suppose the ladder in Chapter 1 holds and L2 takes hold in several areas. What happens next isn't that systems get smarter; it's that they get wider — from one scenario to adjacent processes, then across institutions. This chapter projects the three stages of that expansion, and what settlement, identity and pricing look like once machines become customers.

THE CLAIM

Finance will not get one dominant "AI brain." It will get a layered operating system: payment rails handle execution, systems of record hold the facts, and a governance layer handles evidence and accountability. Value will concentrate in those three layers, not in the model layer.

2.1

Three stages of expansion

2.2

When machines become customers

2.3

Settlement, identity and pricing rearranged

2.4

Who becomes the operating system

2.1 Three stages of expansion

Once a system has L2 working in one area, the team's next move is almost always the same: not to make that area better, but to **connect it to the one next door**. That's not ambition; it's economics. Automation gains in a single area plateau quickly, while connecting an adjacent process costs far less than acquiring customers from scratch.

Stage one: a single closed loop. Read, judge, act and audit within one area. The boundary is clear: the system touches one document type, one interface and one accountable owner. Its value ceiling is equally clear — roughly that area's labor cost plus its error cost.

Stage two: across processes. Chain adjacent steps together — reconciliation into collections, collections into provisioning, provisioning into filing. Value multiplies rather than adds, because what gets removed is the waiting and information loss between steps. But the hard part changes immediately: **different processes usually have inconsistent permission systems, identity definitions and approval chains**, all of which were invisible at stage one.

Stage three: across institutions. One institution's systems interact directly with another's — a supplier's receivables matched against a buyer's payables, a merchant's dispute against an issuer's rules. This stage holds the most value, but what it needs is no longer within any one company's control: **protocols, liability allocation and dispute arbitration**.

The stages aren't linear. Each step up adds roughly an order of magnitude of achievable value — and an order of magnitude of governance complexity. And **governance complexity usually arrives before the value does**. That's why so many teams stall at stage two: they underestimate the work of unifying permissions and identity, which is neither glamorous nor easy to charge for.

Expansion is economics, not ambition
Single-area automation gains plateau fast; connecting adjacent processes costs far less than winning new customers. Every product that gets L2 working will expand outward.

Stage two is a graveyard
Expanding across processes means unifying identity, permissions and approval chains first — a huge, invisible body of work that's hard to charge for on its own. Most teams die here.

Costs that come before the value
Governance complexity must be paid for before any value appears. That's why only well-resourced players, or those with an existing platform position, can go the distance.

Figure 2.1 · Three stages of expansion: scope, value and new difficulties

Stage	Scope	New source of value	New difficulty	Prerequisite
1 Single loop	One area, one document type, one owner	Labor cost + error cost	Confidence, rollback, audit trail	Technical prerequisites suffice
2 Cross-process	Adjacent steps within one institution	Removes waiting and information loss between steps	Inconsistent permissions, identity and approval chains	A unified identity and permission model
3 Cross-institution	Systems at different institutions interact directly	Removes reconciliation, dispute and credit friction	Protocols, liability allocation and arbitration	Industry-level standards; see Ch. 3d

How to read it: moving down, value and governance complexity each grow by roughly an order of magnitude. But governance costs are paid before value is realized — the main reason expansion fails.

A counter-intuitive corollary: **the companies best suited to stage two are often not the ones best at stage one**. Winning at a single point takes deep domain understanding; succeeding across processes takes identity and permission infrastructure — closer to a platform capability than a product one. This explains why so many single-point champions end up absorbed or bypassed by platform players.

The fate of single-point champions
Domain understanding doesn't automatically become platform capability. Stage two needs an entirely different set of engineering and organizational assets.

2.2 When machines become customers

Cross-institution expansion raises a problem finance has never seriously dealt with: **the party initiating a transaction may not be a person.** Not a person using a tool, but an authorized software agent acting for an individual or a business, choosing counterparty, timing and amount on its own.

This isn't a distant hypothetical. Shared payment tokens, agentic commerce protocols, payments MCP servers and AI wallets are all early answers to the same question: **how do you let a software agent safely spend someone else's money?** [16][14][24] The technical details differ, but the problems they have to solve are the same.

Who gets verified changes. Traditional know-your-customer checks verify a natural or legal person. An agent is not a legal person; it is a **chain of delegation**: a user authorized a business, the business configured an agent, and the agent took an action at a given moment. Institutions need to verify the integrity and validity of the whole chain, not just the request at the end of it.

What fraud looks like changes. Fraud prevention used to spot "transactions that shouldn't happen" — stolen cards, counterfeits, account takeover. The hardest category in the agent era is **the legitimate agent that oversteps**: the authorization is real, the agent is real, but what it does goes beyond what the user actually intended. Transaction features alone can't catch this; it takes an explicit statement of authorization scope.

How bargaining works changes. People stay with an institution out of brand loyalty, habit and interface friction; machines don't. When an agent can compare ten providers' fees and settlement times in milliseconds, **margins sustained by information asymmetry and switching costs get squeezed systematically.** That's bad news for any business that lives on them.

Who owns a dispute changes. If an agent places the wrong order, whose fault is it — the user's, the business's, the agent vendor's, or the institution that accepted the transaction? Today's chargeback rules are built around "the cardholder didn't authorize it." They have no slot for "it was authorized, but the agent misunderstood." That is the central issue of Chapter 3d.

KYC → KYA

What needs verifying is no longer a single party but a delegation chain: user → business → agent → action. If any link fails, the whole authorization should fail.

The hardest fraud

Not forgery, but the legitimate agent that oversteps. Real authorization, real identity, but behavior beyond the user's actual intent. Transaction features can't detect it.

Margin compression

Machines don't stay because the interface looks nice. Every business that profits from switching friction will be repriced once agents are common.

The gap in chargeback rules

Current rules are built around "the cardholder didn't authorize it." "Authorized, but the agent got it wrong" has no corresponding clause.

Figure 2.2 · Six structural differences between human and machine customers

Dimension	Human customer	Machine customer	Most affected function
Identity	A single party, verifiable directly	A delegation chain; each link verified and revocable	KYC, account opening
Intent	Implicit in behavior, inferred after the fact	Must be stated explicitly as an authorization scope	Authorization and risk
Frequency & size	Infrequent, varied amounts	High-frequency, small, batchable	Clearing and settlement costs
Comparison shopping	Swayed by brand and friction	Near-perfectly rational; routes instantly	Margins and fees
Fraud pattern	Identity forgery, account takeover	Legitimate agents that overstep	Fraud models
Dispute ownership	Mature rules, ample precedent	No rules; unclear chain of liability	Chargebacks and arbitration

Five of the six rows point to the same thing: today's financial infrastructure assumes a person is on the other side. Once that assumption loosens, far more than the risk model has to change.

2.3 Settlement, identity and pricing rearranged

If machine customers become the norm, three pieces of infrastructure get rearranged first. What they share is that today's designs assume transactions are initiated by people, happen at limited frequency, and carry a meaningful amount each.

Settlement. Machine transactions tend to be smaller, more frequent and more fragmented. Faced with that flow, the fixed per-transaction cost of today's clearing systems becomes hard to bear — not because it's technically impossible, but because the fee structure doesn't fit. There are three likely responses: batch netting, book-transfer within accounts with periodic clearing, and execute-first-reconcile-later against pre-funded limits. **All three lead to the same conclusion: whoever holds the balance captures a new economic benefit.**

Identity. What's needed is no longer an identity but a **verifiable, scoped, revocable delegation credential**, able to express something like: "this agent may, over the next seven days, pay allowlisted counterparties for this category of goods, up to a cumulative amount." Whoever defines the standard for such credentials decides who sits at the center of the authorization chain.

Pricing. When the cost of comparison approaches zero, differences between products collapse onto a few quantifiable dimensions: fees, settlement time, success rate and dispute handling. The premium for brand and interface falls sharply. Good news for new entrants, bad news for institutions that charge on existing relationships.

Taken together, the three suggest where value will move: **from the interface that touches the user, to the account that holds limits and credentials, and then to the protocol that defines what an authorization means.** Interfaces get cheap, because agents don't need them. Accounts matter more, because limits have to live somewhere. Protocols become decisive, because they decide whose authorization is recognized.

Whoever holds the balance wins
All three settlement responses leave funds sitting in some intermediate account. It is the most direct — and most underestimated — economic benefit in the agent economy.

Four elements of a delegation credential
Validity period, scope, limit and counterparty allowlist. Without any one of them, the authorization can't be executed safely by a machine.

The devaluation of interfaces
Agents don't need pretty interfaces. Products whose moat is user experience are in the most awkward position this cycle.

The direction of value
Interface → account → protocol. The further along, the harder to replace — and the harder to see.

Figure 2.3 · How value moves once agents are common: who gains, who loses

Function	How it makes money today	Once agents are common	Our view
Front-end interface & traffic	Acquisition, habit, conversion funnels	Agents bypass the interface and call directly	Clear loser
Information brokers & comparison	Information asymmetry and paid placement	Comparison costs approach zero	Clear loser
Accounts & limit holding	Float and reserves	Limits have to be held somewhere	Winner
Clearing & rails	Per-transaction or ad valorem fees	Far more transactions, each smaller	Structural winner, but fees must change
Authorization & protocol standards	Almost no revenue today	Becomes an unavoidable step	Biggest winner
Disputes & arbitration	A cost center	Becomes a service once rule gaps are filled	Turns from cost into revenue

A conditional projection: it holds only if agent-initiated transactions reach a meaningful share. If agents stay in a supporting role for long, the table as a whole does not hold.

2.4 Who becomes the operating system

"Operating system" is an overused term, so it needs a strict definition. Something is an operating system if and only if it meets two conditions: **others build on top of it**, and **it defines the permission model**. The second matters far more than the first — real control comes from deciding who may do what.

By that standard, no AI product in finance today is an operating system. But three kinds of players are closing in from different directions, and they are approaching **different layers**.

Payment networks are closing in on the execution layer. They already have money-movement interfaces, outcome data across merchants and working dispute processes. What they lack is command of facts inside the enterprise — they know how money flows, not how it should be booked.

System-of-record vendors are closing in on the fact layer. Tax and accounting software, terminals and data platforms hold the authoritative version of business facts. What they lack is an execution interface — they know what should be done but have to go through someone else to do it.

Super-apps and ecosystems are closing in on the entry layer. They combine use cases, identity and payments, and in theory are closest to full-stack. Their problem isn't capability but **openness**: a closed ecosystem can become its own operating system, but rarely the industry's.

My view: **there will be no single AI operating system for finance, but a three-layer division of labor** — payment rails handle execution, systems of record hold the facts, and a governance layer handles evidence and accountability. The layers will fight hard over their borders, but none will swallow the other two, because their strengths come from entirely different sources: one from licences and networks, one from customer data and switching costs, one from regulatory recognition and professional liability.

If this holds, the layer most worth watching is actually the third. The execution and fact layers have clear incumbents, while **the governance layer is nearly empty today** — nobody is systematically turning evaluation, logging, permissions and exit into products reusable across institutions. This book considers it the most underrated position.

Where I might be wrong

The weakest link in this chapter is the assumption that machine customers reach a meaningful share. If agents remain assistants for a long time, with a human still clicking to confirm every transaction, the projections in 2.2 and 2.3 fail and value won't move away from interfaces.

The second risk is that the three-layer split proves unstable. If one player captures both execution and facts — say, a payments company acquiring or deeply integrating tax and accounting software — the three layers collapse into two, and the governance layer's independent value shrinks with them.

A strict definition of an OS

Others build on it, and it defines the permission model. The second is where control comes from.

Three challengers, three layers

Payment networks lack facts, record vendors lack execution, super-apps lack openness. None of the gaps is technical.

The ceiling of closed ecosystems

They can become their own operating system but rarely the industry's. Openness decides whether it's a platform or a walled garden.

The most underrated position

The governance layer. Execution and facts have powerful incumbents; governance is almost unoccupied, yet every transaction above L2 has to pass through it.

This chapter's falsification condition

If by 2030 agent-initiated, automatically completed transactions in major markets still don't warrant rules of their own (no dedicated authorization, chargeback or arbitration clauses), this chapter's projection has failed.

CHAPTER THREE · A

Fighting for the Rails

If value concentrates in the execution, fact and governance layers, the next decade is a fight over those three layers. This section takes the first, and the most often misjudged: why execution rights are not diluted by model progress, and who already holds them.

THE CLAIM

Model progress lowers the cost of judgment, not the cost of access. Access costs are made of licences, clearing networks, dispute processes and the capacity to bear liability — none of which fall as compute gets cheaper. That makes execution rights the one asset technical progress cannot dilute.

3a.1

Why execution rights don't dilute

3a.2

The four control rights converge

3a.3

Where China stands

3a.1 Why execution rights don't dilute

Over the past three years, almost every AI-related cost has fallen: inference per unit, fine-tuning, deployment, even the headcount needed to build a working product. That broad decline has created an illusion — that **every moat will be eroded by technical progress**.

Look closely, though, and only one kind of cost has fallen: **the cost of judgment**. Getting a system to know what to do has become cheap. Getting a system permitted to do it has not.

The cost of access is made of four things, none of which has anything to do with compute. **Licences**: initiating money movement usually requires authorization, and obtaining it takes years. **Clearing networks**: connecting requires counterparties to accept you, and acceptance depends on history, scale and trust. **Dispute processes**: handling things after they go wrong is a whole organizational capability, not an API. **Liability capacity**: you need a balance sheet or insurance to absorb the consequences.

The cost curve for all four is **flat or even rising** — tighter regulation makes licences dearer and liability requirements heavier. The result is a scissors gap: the cost of judgment is collapsing while the cost of access holds or rises. **The two blades of that gap point in the direction value is moving**.

This explains something that is otherwise hard to explain. Over the past two years, the companies with the strongest models have not won a matching commercial position in finance. Instead, companies with ordinary models but control of payment or ledger interfaces turned AI into revenue. The difference isn't who is smarter; it's who is allowed to act.

The value of the network shows up in the same place. Stripe says about **92% of transactions on its network come from a card it has seen before**, with models trained on more than 70 trillion data points.^[18] Data like that can't be bought — it is a by-product of execution rights running continuously. **A company must first be allowed to act before it can accumulate the evidence that keeps it allowed to act**.

That leads to a fairly brutal conclusion for founders: **if your product's value comes entirely from the quality of its judgment, you are standing on the side where costs are collapsing**. The next generation of models will erase today's edge, and you are accumulating no asset that resists technical deflation. The only way out is to attach judgment to some form of execution or liability as fast as possible — even if that means slower, heavier and less glamorous.

Two kinds of cost
The cost of judgment is collapsing; the cost of access is rising. Every intuition that "moats will erode" applies only to the first.

Four sources of access cost
Licences, clearing networks, dispute processes, liability capacity. All four accumulate over years, and none depends on compute.

The scissors gap
Tighter regulation will push access costs higher still. The gap will widen, not close.

A test for founders
Ask yourself: will the next generation of models erase my edge? If so, what am I building that doesn't deflate with technology?

Figure 3a.1 · Two costs moving in opposite directions

Cost type	What it includes	Past three years	Going forward	Who benefits
Cost of judgment	Inference, fine-tuning, deployment, headcount to build products	Falling fast	Keeps falling	Everyone — so it's no advantage
Cost of access	Licences, clearing-network acceptance, dispute handling, bearing liability	Flat or rising	Rises further as regulation tightens	Incumbents

This table underpins every conclusion in the book. If the cost of judgment stops falling, or the cost of access starts collapsing, the analytical framework needs rewriting from scratch.

3a.2 The four control rights converge

Break "access cost" down further and you get four control rights that can be held — and taken away — separately. The combination a company holds decides whether it collects rent along this value chain or merely takes orders.

Data rights are ownership of continuous outcome labels: data refreshed automatically with every transaction, which goes stale the moment the business stops. They differ fundamentally from purchased corpora — one is a stock, the other a flow.

Entry rights are the position of system of record: the authoritative version of some business fact lives with you, and replacing you means migrating years of history and process configuration. Their strength is set not by the interface but by switching costs.

Execution rights are the ability to initiate real actions without going through a third party. They are the hardest of the four to obtain and the hardest to erode.

Liability rights are the ability to present complete evidence and absorb losses after something goes wrong. They are often mistaken for a cost; in fact they are **the pass into core processes** — without them, the other three stay stuck at the advice layer.

Apply these four to five benchmark companies and an interesting pattern appears: none is strong on all four, but the way their strengths combine sets each one's ceiling.

Stock versus flow
Purchased corpora are a stock and depreciate; outcome labels flowing back from the business are a flow and appreciate. That's the test for data rights.

Liability rights are systematically underrated
They look like a cost center but are really an entry permit. Without them, even the best judgment stays at the advice layer.

Figure 3a.2 · Which control rights five benchmark companies hold

Company	Data	Entry	Execution	Liability	What the structure implies
Stripe	Strong	Medium	Strong	Medium	Shortest feedback loop; weaker on governance transparency and agent-authorization standards
Ant Group	Strong	Strong	Strong	Medium	The most complete set of rights; constrained by openness and by the lack of separate disclosure of AI's incremental contribution
Bloomberg	Strong	Strong	Weak	Strong	The strongest trust assets, but conclusions can't turn directly into actions
Intuit	Strong	Strong	Medium	Strong	Strong on both records and liability; weaker on globalization and extending standards outward
Hithink RoyalFlush	Medium	Strong	Weak	Medium	Has entry but lacks execution and liability; advertising and online promotion were 57% of 2025 revenue, capping it at traffic monetization ^[23]

Ratings are this book's research judgments based on publicly disclosed product capabilities and business mix; they are not credit or investment ratings.^{[14][16][19][21][23][24]}

Two convergence paths can be read from the table. **The first is "have execution, add facts"**: payment players extend toward the system of record, usually by acquiring or deeply integrating tax, ERP or reconciliation products. **The second is "have facts, add execution"**: record players extend toward money movement, usually by partnering with licensed institutions or building payments in-house.

Two asymmetric paths
Adding facts is a problem money can solve; adding execution often isn't. Record-keeping incumbents' moats are shallower than they look.

The two paths are not equally hard. Adding facts means buying or building software — expensive but predictable. **Adding execution needs licences, network acceptance and liability capacity, which money often can't buy.** So over the long run the first path succeeds more often — a risk today's record-keeping incumbents should take seriously.

3a.3 Where China stands

Apply the same framework to China and you get a clear but lopsided picture: **very strong execution rights, a thin fact layer, and a governance layer under construction.**

Execution is China's thickest layer. The depth of mobile-payment penetration, density of use cases and degree of identity binding are world-leading. Alipay+ extends that execution capability to overseas acceptance by interoperating with local wallets and national QR-code standards, and experiments such as a payments MCP server and AI wallets point squarely at plugging agents into money movement.^{[14][15][24]} This is Chinese companies' most real asset in this round of competition.

The fact layer is the thinnest. Enterprise systems of record are highly fragmented: tax, ERP, supply chain and bank statements belong to different vendors, and penetration is far below comparable products in mature markets. That directly raises the cost of cross-process expansion — linking reconciliation to filing may mean integrating five incompatible systems. It is also the structural reason AI delivery in China skews toward bespoke projects with thin margins.

The governance layer is being rapidly shaped by regulators. The National Financial Regulatory Administration's 32 guiding opinions of 2026 establish that "whoever uses it is responsible," call for technological self-reliance, and require full-lifecycle management spanning requirements, data, development, deployment, operation and exit.^[10] That is both a constraint and an opportunity: **the constraint is compliance cost paid up front; the opportunity is that it turns governance capability into something that can carry a price.**

Put the three layers together and the strategic implications are quite concrete. Chinese companies already lead at the execution layer and have nothing left to prove there. Catching up at the fact layer offers poor returns, because it takes years to accumulate. **The prize actually worth fighting for is the governance layer** — regulators have only just defined it, it has no incumbent, and once it takes shape every cross-institution transaction will have to pass through it.

The logic for going global follows. Copying the domestic retail-finance playbook fails in most markets — no licences, no relationships, no local data. **Payments, treasury, risk and compliance for cross-border merchants** are the exception: execution rights in this segment can be extended, governance capability can be standardized, and local licensed partners have a reason to deliver jointly.

Where I might be wrong

This section assumes execution rights can extend across borders. But success in exporting payments doesn't automatically translate into exporting "agent execution rights" — the latter involves the semantics of authorization and the allocation of liability, both of which differ in every jurisdiction and are highly political. If agent-payment standards end up fragmented by region, China's execution advantage stays locked inside its home market.

The thickest layer

Execution rights. A real asset left by fifteen years of mobile-payment competition; nothing left to prove.

The thinnest layer

Enterprise systems of record. Fragmented, under-penetrated and mutually incompatible, which drives up the cost of cross-process expansion and squeezes delivery margins.

A new layer defined by regulators

The 32 opinions turn full-lifecycle governance into a requirement. A requirement is a market — for the first time, governance capability can be priced on its own.^[10]

The exception abroad

Cross-border merchants: execution can be extended, governance standardized, and local licensed partners have a motive to cooperate. One of the few replicable paths.

This section's falsification condition

If by 2030 major markets' agent-payment authorization standards don't recognize one another, and cross-border agent transactions require fresh licensing market by market, the assumption that execution rights can extend has failed.

Locking the Ledger

While the fight over the rails goes on, a quieter one is under way over data rights, access permissions and supply-chain concentration. What needs locking here isn't model weights but ledgers, logs and keys — what finance really fears has never been stolen capability, but misused permissions.

THE CLAIM

The most likely systemic incident in financial AI is not a bad model judgment but a misconfigured permission or a concentrated third-party failure. The first is a product defect; the second is an industry risk — and almost nobody is pricing the second today.

3b.1

Three things that must be locked down

3b.2

Concentration: the overlooked systemic risk

3b.1 Three things that must be locked down

Once a system is allowed to move money, the shape of the attack surface changes. Traditional information security asks "could data leak?" The agent era must also ask "could permissions be misused?" The second is more dangerous, because it needs no break-in at all — a single misconfiguration will do.

One: data rights. Is there clear authorization to use the data you train and retrieve on? In finance this is not just a compliance question but one of product durability: a dataset of unclear origin can force a product offline after it's already working, breaking the entire loop. A data-rights register belongs at project kickoff, not bolted on during legal review.

Two: access permissions. Agents often need broader permissions than people — reading several systems, calling several APIs. The most common mistake is making convenience the default: give the agent a high-privilege account and rely on the prompt to constrain it. **A prompt is not a permission boundary.** The real boundary must live at the API layer, in the token's scope, not in natural language.

Three: audit and keys. The decision chain must be fully reconstructable: what the inputs were, what was retrieved, which model and prompt versions ran, what the permission snapshot was, and what was finally executed. The integrity of that evidence itself needs protecting — if the system writing the logs can also alter them, they're worthless as evidence.

Together the three impose a direct requirement on product design: **governance must live in the architecture, not in procedures.** "Operating guidelines" written in policy documents are almost useless against agents, because agents don't read policy documents; they are constrained only by interfaces and tokens.

A new attack surface
Not data leakage but permission misuse. No intrusion needed; one misconfiguration is enough.

A prompt is not a permission boundary
In this book's view, the most widespread and most dangerous engineering mistake. The boundary has to be in the token scope.

Trustworthy logs
If logs can be altered by the system that produces them, they have no evidential value. Tamper-proofing is the minimum bar for audit events.

The principle in one line
Governance lives in architecture, not in procedure. Agents don't read policy manuals.

Figure 3b.1 · Three locks: common mistakes and the right approach

Category	Common mistake	Right approach	Consequence of failure
Data rights	Build first, secure authorization later; mix in corpora of unclear origin	Create a data-rights register at kickoff, recording source, scope of authorization and expiry	Product forced offline; the loop breaks
Access permissions	Give the agent a high-privilege account and constrain it with prompts	Least-privilege tokens scoped by limit, counterparty and validity period	Unauthorized actions that are hard to attribute
Audit & keys	Record outcomes but not process; logs share a database and permissions with business systems	An independent, tamper-proof event bus; versioned models and prompts; permission snapshots	No evidence, so no way to allocate liability

What the three rows share: the wrong approach causes no visible problem during a demo and only surfaces after a production incident. That's exactly why these mistakes are so common.

3b.2 Concentration: the overlooked systemic risk

A misconfigured permission at one institution is a product defect, fixable with engineering discipline. The genuinely hard problem is a different one: **the whole industry depending on the same handful of vendors.**

This isn't a theoretical worry. The UK regulators' survey shows **a third of AI use cases are third-party implementations**, 16% of which are rated high materiality.^[4] The Financial Stability Board has explicitly flagged concentration in compute and model supply, third-party dependency, model risk, data quality, cyberattacks and market herding.^{[7][8]} Product teams most often overlook the last one: when many institutions use similar models, similar prompts and similar data sources, their judgments fail at the same time — and **in the same direction.**

This is fundamentally different from traditional model risk. If a bank's in-house credit model fails, the damage stays with that bank. If an entire industry's fraud systems sit on the same few foundation models, one shared failure mode can open holes at many institutions at once. Finance has learned similar lessons before, from credit rating agencies and from risk models.

This risk is currently priced at almost nothing. Procurement assesses a vendor's financial stability and security certifications, but rarely asks **"what happens if this vendor also serves ten of my peers?"** The question won't resolve itself any time soon, because it's never the top priority for any single buyer.

My view: **concentration will become one of the central themes of the next round of fintech regulation, and it will land on vendors in the form of procurement requirements.** Likely forms include model-source diversity, proof of switchability, disclosure of upstream dependencies and direct oversight of critical third parties. For product teams, "replaceability" will turn from a negotiating weakness into a selling point.

There's a counter-intuitive commercial implication here. Most vendors instinctively try to create lock-in, because lock-in means renewals. In this direction, though, **vendors that can prove they are replaceable are more likely to be chosen** — because the buyer's compliance team needs that proof. Productizing the exit mechanism is one of the few designs that is good for the customer and good for the vendor.

Herding

Similar models + similar data = failing in the same direction at the same time. The FSB calls this out by name, yet product teams consider it least.^[7]

A familiar pattern

Finance learned the "everyone uses the same method" lesson with ratings and risk models. Such risks are invisible in normal times and appear everywhere at once.

Concentration won't fix itself

It is never any single buyer's top priority, so only regulation or industry standards can drive it.

A counter-intuitive selling point

Vendors that can prove "I can be replaced" win more tenders. Exit mechanisms are one of the few designs that benefit both sides.

Figure 3b.2 · Three forms of concentration and how to respond to each

Where it concentrates	What happens when it fails	What buyers can require	What vendors can sell
Compute & foundation models	The same judgments degrade across many institutions at once	Model-source diversity; proof of switchability	Multi-model routing with consistency guarantees
Data & knowledge sources	One bad dataset contaminates conclusions industry-wide	Disclosure of data sources; cross-validation	Independent data verification services
Middleware & agent frameworks	One vulnerability is exploitable at many firms at once	Dependency inventories; vulnerability-response commitments	Auditable dependency governance and incident drills

The shared structure of all three rows: what buyers need is exactly what vendors can productize and price separately. This is the most direct route to commercializing the governance layer.

The Trustworthiness Problem

How do you let a system you don't fully understand move money? It sounds like a philosophical question, but finance doesn't need to answer the philosophical version — only the engineering and contractual one. This section argues that trustworthiness is a product problem, and that workable solutions already exist.

THE CLAIM

Trustworthiness doesn't come from "making the model more reliable." It comes from placing unreliable components inside a reliable structure: limits, circuit breakers, dual-track checks, human-review triggers and reversible execution. The ability to design that structure will be the scarcest product skill of the next decade.

3c.1

Fix the structure, not the model

3c.2

Five structural components

3c.3

Put it in the contract

3c.1 Fix the structure, not the model

Faced with the fact that models can be wrong, engineering teams' first instinct is usually to make them wrong less often: better prompts, more fine-tuning, stronger retrieval. That path has value, but it has one fatal property — **it never reaches zero**. And what finance needs isn't zero errors; it's **consequences that stay contained when errors happen**.

That distinction produces two entirely different product philosophies. The first tries to make components reliable enough. The second accepts that components are unreliable and designs a structure that can contain them. **Finance itself is a product of the second philosophy**: double-entry bookkeeping assumes clerks make mistakes, four-eyes review assumes one person will err, limits assume judgment will fail, and clearing and reconciliation assume transmission will go wrong.

So the right question isn't "is this model accurate enough?" but "**when it's wrong, who notices first, how big is the loss, and can it be reversed?**" The answers to those three questions matter far more than two extra points of accuracy.

This brings a conclusion engineering teams may find uncomfortable: **most of the work of trustworthiness is not on the model side**. It's in limit design, trigger rules, rollback paths, event logging and the hand-off interface with humans. None of it makes a dazzling demo, but it is the only bridge between L1 and L2.

Intuit's approach is instructive here. It doesn't pretend AI can replace tax experts; instead it explicitly builds review by CPAs and tax experts into its products and services.^{[19][20]} That looks like admitting the technology falls short. In fact it is **using a structural component to buy entry into a high-liability arena**.

The core distinction

Not "prevent errors" but "keep the consequences of errors contained." The whole institutional apparatus of finance is built on the second philosophy.

Three questions that replace accuracy

Who notices first? How big is the loss? Can it be reversed? These answers decide whether an area can cross into L2.

The uncomfortable conclusion

Most trustworthiness work isn't on the model side. It makes no dazzling demo, yet it is the only bridge from L1 to L2.

Building human review into the product

Not an admission of technical weakness, but a structural component that buys entry into high-liability work.

Figure 3c.1 · Two product philosophies compared

Dimension	Make the component more reliable	Make the structure contain unreliability	Finance's choice
Where the work goes	Prompts, fine-tuning, retrieval, evaluation	Limits, circuit breakers, dual tracks, rollback, logging	Mainly the latter, supported by the former
Convergence	Improves asymptotically; never reaches zero	An upper bound on consequences can be set explicitly	The latter
Negotiability	Hard to write into a contract	Every element can become a clause	The latter
Explainability to regulators	Depends on model-interpretability research	Depends on process and chain of evidence	The latter

This isn't to say model quality doesn't matter. In finance, model quality decides whether a product is good to use; structural design decides whether it can go live at all.

3c.2 Five structural components

Made concrete, the principle of the previous section yields five components of trustworthiness. They aren't options but a minimal complete set — without any one of them, a system can't safely cross into L2.

- 1. Limits.** A per-transaction cap, a daily cumulative cap, a per-counterparty cap. Limits don't prevent errors; they **put a tolerable upper bound on the total size of errors**. They should be adjustable by customer, scenario and time, and every adjustment must be logged.
- 2. Circuit breakers.** When anomaly rates, amount distributions or decline rates drift far enough from baseline, execution stops automatically and passes to a human. What matters isn't how precise the threshold is, but that it is **triggered by the system itself** rather than depending on someone happening to watch a dashboard.
- 3. Dual-track checks.** Re-check critical decisions along a path independent of the main model — a rules engine, a traditional model, or a model from a different source. Independence matters more than accuracy: **two paths from the same source will make the same mistake at the same time**.
- 4. Human-review triggers.** Write "when a human is needed" as decidable rules, not "confirm manually when it matters." Workable triggers include confidence below a threshold, amounts above a tier, customer segment, historical anomaly flags and a first transaction with a new counterparty.
- 5. Reversible execution.** Prefer action forms that can be undone: pre-authorization rather than immediate capture, drafts rather than submissions, freezes rather than transfers. When an action is irreversible, human-review triggers must tighten significantly.

The five involve an important trade-off: **tightening any one of them lowers the automation rate**. So the core work of product design is finding the combination with the highest automation rate within a given risk budget — an optimization problem you can quantify, iterate on and show to customers. That is where the real technical depth of these products lies.

A minimal complete set
Limits, circuit breakers, dual tracks, review triggers, reversibility. Missing any one, L2 can't be crossed safely.

What limits really do
They don't prevent errors; they cap the total size of errors. It's the one thing you can explain clearly to a risk committee.

Independence > accuracy
A dual-track check from the same source as the main path is no check at all — both will make the same mistake together.

The real technical depth
Maximizing the automation rate under a given risk budget: a quantifiable, iterable, demonstrable optimization problem.

Figure 3c.2 · The five components and the failure modes each one stops

Component	What it stops	What it doesn't stop	The cost of tightening it
Limits	Runaway single or cumulative losses	Steady leakage through frequent small amounts	Large-ticket business can't be automated
Circuit breakers	Systemic shifts and sudden drift	Slow degradation that stays within baseline	False trips interrupt the business
Dual-track checks	Systematic errors on a single path	Blind spots shared by both paths	Double the cost; higher latency
Review triggers	High-risk individual cases	Reviewer fatigue and rubber-stamping	Labor costs return and offset the gains
Reversible execution	Consequences of actions already taken	Time-critical, irreversible situations	Worse user experience; longer flows

The "doesn't stop" column often matters more than the "stops" column — it defines residual risk, and residual risk is exactly what insurance and compensation clauses have to cover.

3c.3 Put it in the contract

While the five components exist only in code, they're engineering details. Once they appear in a contract, they become commercial assets. This is the step technical teams are least used to and the one that matters most.

The reason is simple: the buyer's procurement, risk and legal teams need something they can sign. "Our system is robust" can't be signed. "A per-transaction execution cap of ¥10,000; automatic circuit break when anomalies exceed twice the baseline; mandatory human review above ¥50,000; errors compensated up to this cap" can. **Translating technical capability into clauses is, in essence, doing the customer's internal business case for them.**

Writing clauses also improves the product: the moment you must commit to a compensation cap, you see which residual risks you won't carry — precisely where the product should go next. **A contract is the most honest roadmap.**

Six clauses need spelling out. They don't map one-to-one onto the five components in 3c.2; rather, they bind components, evidence and consequences together.

The most overlooked is **the baseline and evaluation method**. Without a human baseline both sides accept, any claim of "improved results" is just marketing; once the baseline is in the contract, outcome-based pricing becomes legally enforceable. It has to be done during the pilot; afterwards the manual process has changed and the baseline can't be measured retroactively.

Exit and data return is also a pricing tool: a vendor willing to commit to a full exit mechanism can charge a higher unit price, because the buyer saves an entire vendor-risk assessment.

From usable to sellable

The five components are engineering details in code; written into a contract, they become commercial assets.

Write the customer's business case

Procurement, risk and legal need something signable. Clauses translate technical capability into the language they work in.

A contract is the most honest roadmap

The residual risk you won't commit to compensating is exactly where the product should go next.

Baselines must be set during the pilot

They can't be measured retroactively — by then the manual process has changed. The most common, and most fatal, omission.

Figure 3c.3 · Six must-have clauses and the component each one binds

Clause	What it must spell out	Component bound	If it's left out
Scope	Which customers, document types and amount ranges are in scope	Scenario boundary	Scope creep; unbounded liability
Limits & restricted authority	Per-transaction, daily and per-counterparty caps and how they change	Limits	No upper bound on losses
Human-review triggers	Decidable rules, not "confirm when it matters"	Review triggers	Review becomes a box-ticking exercise
Baseline & evaluation method	How the human baseline is sampled, who owns the eval set, how often it's re-checked	Dual-track checks	Outcome pricing is unenforceable
Compensation limits	Error severity tiers, compensation caps, exclusions	Circuit breakers & rollback	No basis for disputes; the relationship breaks
Exit & data return	Export formats, asset ownership, length of transition period	Replaceability	Customers won't integrate deeply

Make these six a standard schedule rather than negotiating them line by line each time. Standardization is itself proof of capability, and it markedly shortens procurement cycles at large institutions.

Where I might be wrong

This section assumes buyers are willing to sign clauses with compensation terms for AI decisions. The opposite equilibrium is possible: buyers insist "all liability sits with the vendor," vendors can't carry it, and both retreat to low-limit, low-value pilots that never scale. If no established template for compensation clauses emerges within three years, this path needs rethinking.

This section's falsification condition

If by 2029 the industry still has no reference template for AI-decision compensation clauses, or insurers still refuse to underwrite the risk, the path to commercializing trustworthiness has failed.

The Standards War

Rails, ledgers and trustworthiness are all problems a single company can solve internally. Standards are not. Whoever defines the semantics of agent authorization, chargeback liability and cross-border recognition decides who collects rent and who pays it for the next decade — and this contest is barely being discussed in public.

THE CLAIM

China, the US and the EU are building three governance frameworks on different logics: China regulates by accountable party and lifecycle, the US by use and materiality, the EU by risk tier. They won't unify any time soon, so "compliance adaptation" will itself become a business that can be sold on its own.

3d.1

Three governance logics

3d.2

The standards gap in agent payments

3d.3

What China can win

3d.1 Three governance logics

Read the three jurisdictions' regulatory documents side by side and the direction is strikingly consistent: risk tiers, full lifecycle, traceability. But **the logic that organizes those requirements is completely different** — and the differences fall exactly where they affect product design most.

China organizes around the accountable party and the lifecycle. The NFRA's 32 guiding opinions of 2026 state that "whoever uses it is responsible," stress technological self-reliance, require coverage of the full chain from requirements, data and development through deployment, operation and exit, and focus supervision on high-risk scenarios.^[10] The lever is **the user**: financial institutions bear full responsibility for the AI they use, and vendors are constrained indirectly through the institutions' compliance requirements.

The US organizes around use and materiality. Treasury's AI risk management framework for financial services and the revised model-risk guidance build on the existing risk-management regime, emphasizing tiering by use, materiality assessment, third-party risk, independent validation, transparency and resilience.^[11] The lever is **the materiality of the risk**: the more material the model, the higher the bar for validation and governance — with materiality argued by the institution and examined by the regulator.

The EU organizes around risk classification. The AI Act places credit scoring and some insurance pricing among potential high-risk categories, requiring data quality, log retention, human oversight and robustness; DORA already covers ICT resilience and critical third-party risk.^{[12][13]} The lever is **the classification of the system itself**: first determine what kind of AI it is, then apply the matching list of obligations.

The practical consequences are very concrete. Taking one product into all three markets means answering three different questions: in China, "can the institution using it prove control across the full lifecycle?"; in the US, "how material is this use, and is validation independent?"; in the EU, "which category does it fall into, and are the matching obligations all met?" **The evidence for these three questions is not interchangeable.**

That leads to a commercial conclusion: **compliance adaptation will become a product layer in its own right.** It isn't translating documents into three languages; it's mapping one set of capabilities onto three different evidence structures — the same logs organized and presented three ways. Companies willing to productize this can turn everyone else's cost into their own revenue.

Same direction, different logic
All three want tiering, full lifecycle and traceability, but organize it differently: China regulates the party, the US materiality, the EU classification.

Why the differences matter
They decide what evidence you need. The same logs must be organized three ways for three jurisdictions, and one can't stand in for another.

The compliance adapter
Mapping one set of capabilities onto three evidence structures. In this book's view, the clearest standalone product opportunity.

Don't expect unification
Behind the three logics lie three regulatory philosophies and political structures. What converges in the near term is direction, not interfaces.

Figure 3d.1 · What the three governance logics mean for products

Jurisdiction	Organizing logic	Core requirements	Concrete impact on products	Evidence you need
China	By accountable party and full lifecycle	Whoever uses it is responsible; self-reliance; records across the chain from requirements to exit ^[10]	On-premise deployment and domestic-stack compatibility become entry requirements	Complete records of development and operation
US	Tiered by use and materiality	Tiering by use, independent validation, third-party risk, transparency and resilience ^[11]	Reproducible validation documentation and a model inventory	Independent validation reports and materiality assessments
EU	By risk classification of the AI system	Data quality, logging, human oversight and robustness for high-risk uses ^{[12][13]}	Log retention is a mandatory feature, not an add-on	Conformity assessments and technical documentation

The "evidence you need" column doesn't overlap across rows — which is exactly the value of a compliance adapter: collect once, organize three ways.

3d.2 The standards gap in agent payments

All three frameworks discuss "how AI systems should be governed," yet almost none answers the concrete question raised in Chapter 2: **when an agent initiates a transaction on a user's behalf and gets it wrong, who pays?**

This isn't an oversight but a matter of timing — regulators usually step in only once a phenomenon reaches scale. But that gap is precisely **the window in which standards form**, and once formed, standards are extremely hard to change. Many of the rules in payments were settled in similar windows, and first movers' designs often became de facto standards.

Three kinds of players are currently trying to fill the gap, each with its own logic. **Payment networks** push shared tokens and agentic commerce protocols, aiming to fold agents into existing authorization and dispute systems while changing as few rules as possible. **Platforms and ecosystems** push their own agent-access schemes (payments MCP servers, AI wallets and the like), aiming to make it work inside their own ecosystem first and export it later.^{[14][16][24]} **Model and device makers** want the agent layer to stay neutral, so they aren't tied to any single payment provider.

Their interests genuinely conflict. Payment networks want liability to follow existing rules, which favor them; platforms want liability kept inside their ecosystems, where they control it; model makers want liability to fall on the payment side, because they can't bear financial risk. **No party can set the standard alone**, so the likeliest outcome is a long period of competing standards, until an incident at scale forces regulators to step in.

For Chinese companies this gap carries a particular meaning: **an execution advantage only turns into cross-border revenue in a world where standards are mutually recognized**. If standards fragment by region, even the strongest domestic execution capability remains a domestic asset. That gives participation in international standards discussions — even just proposing technical designs others can cite — strategic value beyond any direct commercial return.

The gap is the window
Regulators arrive after a phenomenon scales. The de facto standards formed in the gap often become the final ones.

Real conflicts of interest
Payment networks want the old rules, platforms want liability kept in-house, model makers want it pushed onto payments. None can set the standard alone.

The likeliest outcome
Competing standards until an incident at scale forces unification. That means the window is longer than most people expect.

What it means for Chinese companies
Execution rights are a cross-border asset only in a world of mutual recognition. Taking part in standards work is worth more strategically than it earns directly.

Figure 3d.2 · Four ways to allocate liability when an agent transaction goes wrong (none has mature rules yet)

Allocation	Who bears the loss	Who favors it	Main problem
Apply unauthorized-use rules	The institution or merchant that accepted the transaction	Users and consumer-protection advocates	The agent was authorized, so the premise fails
Authorization means no recourse	The user	Payment providers and merchants	Users can't foresee everything an agent will do
Agent vendor is liable	The company that provides the agent	Payment networks and platforms	Model makers can't carry financial risk
Tiered by authorization scope	User within scope; vendor when the agent oversteps	This book's pick for the likely mainstream	Needs a common way to express authorization

The fourth option requires "authorization scope" to be expressed in machine-readable form. Whoever's way of expressing it is widely adopted owns the definition of this layer.

3d.3 What China can win

Putting the previous sections together allows a concrete judgment about the positions Chinese companies can realistically take in this round. I think three are winnable, and two most likely are not.

Winnable, one: agent payments and treasury for cross-border merchants. Customers here are Chinese-owned merchants or those serving China's supply chains, with a natural dependence on Chinese payment capabilities. Execution rights can be extended, governance can be standardized, and local licensed partners have a reason to deliver jointly. This is the most realistic path abroad.

Winnable, two: exporting the governance layer as a product. Chinese regulators' requirements for full-lifecycle records, self-reliance and exit mechanisms effectively force domestic vendors to build these capabilities earlier.^[10] Packaged as standalone modules rather than rebuilt for every project, they are in demand in other heavily regulated markets too — the **form** of the requirements differs, but the **evidence** needed overlaps heavily.

Winnable, three: domain evaluation assets built on Chinese-language and local data. Public domain evaluation sets are a cheap, high-leverage form of standards influence. Hithink RoyalFlush open-sourcing BizFinBench and building Chinese financial Q&A benchmarks is the right direction^[23] — evaluation sets become references in procurement, and being referenced is influence.

Probably not winnable, one: a globally adopted standard for authorization semantics. This layer is deeply bound up with payment networks' existing rules and with each jurisdiction's consumer-protection regime; control will most likely stay within the established international payments and regulatory system. The realistic goal is to be "compatible," not "adopted."

Probably not winnable, two: exporting the domestic retail-finance playbook wholesale. Licences, credit-reporting systems, consumer-protection rules and acquisition costs all differ, and past attempts don't support this route. **Rather than copy retail, go after merchants.**

Taken together, the five suggest a strategic posture: **defend the existing lead at the execution layer, attack at the governance layer, and aim for compatibility at the standards layer.** That's more realistic than "benchmark against everyone on everything," and more likely to leave real assets ten years from now.

The most realistic path abroad
Payments, treasury, risk and compliance for cross-border merchants. Execution extends, governance standardizes, local partners are motivated.

Different form, overlapping evidence
The three jurisdictions want evidence presented differently, but the underlying evidence to collect is largely the same. That's why governance modules can be reused across markets.

Evaluation sets are influence
An evaluation set cited in procurement documents ends up defining what "qualified" means. Cheap standards influence.^[23]

The realistic goal is compatibility
At the authorization-semantics layer, being "adopted" isn't realistic; ensuring you're "compatible" is achievable.

Figure 3d.3 · Three fights to pick, two to skip: positions open to Chinese companies

Posture	Target	Basis	Test of success
Fight	Agent payments and treasury for cross-border merchants	Execution rights extend; local licensed partners motivated to deliver jointly	Share of revenue from standard products rather than bespoke projects
Fight	Exporting the governance layer as a product	Domestic rules forced the capability to be built early, and evidence overlaps heavily across jurisdictions ^[10]	Whether governance modules can be priced separately and win repeat purchases
Fight	Domain evaluation assets on Chinese-language and local data	Public evaluation sets are cheap, high-leverage standards influence ^[23]	Whether they're cited in procurement documents and regulatory Q&As
Skip	A global standard for authorization semantics	Deeply tied to existing payment rules and local consumer protection	Reset the goal to "compatible," not "adopted"
Skip	Copying domestic retail finance abroad	Licences, credit reporting, consumer protection and acquisition costs are all different	Success means not investing

The point of this table is to be explicit about what not to fight for. Most strategies fail not by choosing the wrong direction but by choosing too many at once.

CHAPTER FOUR

How Regulation Arrives

Public debate about AI regulation mostly asks whether something will be banned. In finance that's the wrong question — finance never bans a technology; it decides who may use it and on what terms. This chapter projects the form regulation will actually take, and what that means for products.

THE CLAIM

Regulation won't arrive as prohibition but as conditions for market access. Once evaluation, logging, permissions, fallback and exit are written into tender documents, the market will go through a complete vendor shake-out without a single ban.

4.1

Not prohibition, but access

4.2

Three possible institutional arrangements

4.1 Not prohibition, but access

Financial regulators rarely ban a technology outright. Their more usual tool is to **raise the bar for using it** — require validation, records, capital, human review. In effect this resembles a partial ban, but the form is entirely different: the technology isn't illegal; using it just becomes much more expensive.

The distinction matters enormously to product teams. If you expect a ban, your response is to lobby and wait. If you expect access conditions, your response should be **to turn the conditions into features ahead of time**. The second is an engineering task you can start today.

The outline of this form is already visible. The US Treasury's FS AI RMF, published in February 2026, isn't legally binding, yet it breaks AI governance into **230 control objectives** arranged under govern, map, measure and manage.^[11] The real effect of such "soft law" isn't punishment; it defines what examiners will ask — and what examiners ask ends up on procurement checklists. The tiering, full lifecycle, traceability, third-party risk and human oversight that all three jurisdictions require will eventually become concrete checklist items.^{[10][11][12]} Once they do, vendors that fall short aren't fined; **they can't even bid**.

That's what I mean by "a shake-out without a ban." Suppose that from some year on, major institutions' tenders uniformly require an independent evaluation report, tamper-proof audit events, a fine-grained permission model, a rehearsed fallback plan and enforceable exit and data-return clauses. Most of today's active AI vendors would be eliminated on that one page — not because their products are bad, but because none of this was ever on their roadmap.

Conversely, this is the clearest opportunity in the book. **Access conditions can be known in advance**: the regulatory documents are public, the direction is consistent, and all that's left is translating them into features and documentation. Teams willing to finish this before anyone asks will, at the moment of the shake-out, hold a lead others need two years to close.

Regulators' real tool
Not prohibition but higher conditions of use. The technology stays legal; using it just costs more.

Two expectations, two responses
Expect a ban → lobby and wait. Expect access conditions → build the conditions into features now. The second can start today.

How vendors get eliminated
Not fined, just ineligible to bid. There's no appeal against this kind of elimination.

Why this is the clearest opportunity
The access conditions are already public in regulatory documents. A rare exam where you can know the answers two years early.

Figure 4.1 · From regulatory principle to tender clause: a predictable chain of translation

Regulatory principle (public)	The tender clause it becomes	Matching product feature	Cost to build now
Tiered, categorized management	Differentiated controls by scenario risk level	Tiered authorization and scenario-specific limits	Low
Full-lifecycle traceability	Tamper-proof decision-chain records retained for N years	Independent audit event bus	Medium, and rising the longer you wait
Independent validation	Evaluation reports from a third party or independent team	Standardized eval sets and report generation	Medium
Human oversight	Explicit human-review triggers and review records	A decidable review-rules engine	Low
Third-party risk & resilience	Disclose upstream dependencies; provide switching and exit plans	Productized dependency inventory and exit mechanism	High, but can be charged for separately

The last column is the key: the cost of building these features rises over time (the more data you have, the harder it is to backfill records), while the payoff jumps once regulation lands. A clear "cheaper if done early" structure.

4.2 Three possible institutional arrangements

Beyond access conditions, three heavier institutional arrangements may emerge. What they share is that each turns something that is an internal company matter today into industry-level public infrastructure.

First: industry-level evaluation and certification. Regulators, industry associations or authorized third parties maintain public evaluation sets, and vendors must be certified to enter certain scenarios. Other regulated industries have mature precedents. The benefit is lower validation costs for every buyer; the risk is that the evaluation set itself gets over-optimized and becomes a new exam to teach to.

Second: mandatory incident disclosure. Institutions must report AI-related production incidents, and de-identified failure modes are shared across the industry. This is the most likely source of the data actuaries need, so it also unlocks the insurance window discussed in Chapter 1. **If I had to pick one institutional signal to watch, it would be this one.**

Third: direct oversight of critical third parties. When some vendors' failure would hit many institutions at once, regulators may bypass the indirect route of "institutions answer for their vendors" and impose requirements on vendors directly. The EU's DORA has already built this kind of mechanism for ICT resilience.^[13] For leading vendors it cuts both ways: compliance costs rise, but so do barriers to entry.

The likely sequence: access conditions first (already happening), mandatory disclosure second, and direct oversight last, applying only to a few critical vendors. Product teams need to prepare actively for the first two; the third concerns very few companies.

Two common misconceptions are worth separating out. The first treats regulation as pure cost — in fact access conditions are also a **competitive barrier**: they keep out rivals unwilling to do this work, work you'll have to do sooner or later anyway. The second treats regulation as paperwork you can fill in afterwards — but audit trails, permission models and exit mechanisms are architectural decisions, and **the later you change them, the more it costs, exponentially.**

One more judgment about timing is worth recording: institutional arrangements usually accelerate **after the first incident at scale**. That means the industry's actual pace may be set not by regulators acting proactively but by a single public incident. So making "what evidence must we produce within 48 hours of an incident?" a design input is more useful than predicting when regulatory documents will be published.

Where I might be wrong

This chapter assumes regulation keeps tightening. But regulators also feel competitive pressure: if a major economy concludes that strict governance is hurting its competitiveness, it may loosen, and other jurisdictions may follow.

That would fundamentally change this book's conclusions — the premium on governance capability would vanish, and speed and scale would once again be the only variables.

The signal most worth watching

Mandatory incident disclosure. It is the source of actuarial data, and therefore the key step in unlocking L3.

The side effect of certification

Once a public eval set becomes an entry requirement, it gets over-optimized. Every standardized test suffers this; it can't be avoided, only refreshed regularly.

The DORA precedent

The EU already directly oversees critical ICT third parties. There's a real chance the AI supply chain goes the same way.^[13]

This chapter's falsification condition

If any major economy explicitly loosens financial AI governance "to stay competitive" and other jurisdictions follow, this chapter's — and the whole book's — view of the governance premium must be revised down.

Chapter 5 Six bets

A projection is worth something not because it sounds reasonable but because it can be tested. The six items below compress every claim in this book into bets: each has a clear time frame, a clear falsification condition, and what you should do now if it holds.

How to use this list

Check the falsification conditions each quarter. When one is triggered, revise the corresponding action — not the whole framework.

1	The governance stack becomes a procurement threshold before model capability does Evaluation, logging, permissions, fallback and exit enter mainstream tenders as standalone clauses, and vendors that don't meet them lose eligibility to bid. <i>Falsified if: by 2029, mainstream financial institutions' tenders still compare only model benchmarks and price.</i>	2026 — 2028 High confidence
2	The trusted amount clearly leaves zero in several areas In at least one of refunds, reconciliation, collections or fraud prevention, routine execution appears without per-transaction human review, with limits and rollback. <i>Falsified if: by end-2029, no category of financial action is broadly allowed to execute without per-transaction review.</i>	2026 — 2029 High confidence
3	Mandatory incident disclosure arrives before insurance products Regulators require AI production incidents to be reported and failure modes shared; only then does insurable AI-decision liability cover appear. <i>Falsified if: insurance products appear at scale before any mandatory disclosure regime.</i>	2027 — 2031 Medium confidence
4	Agent payments will run on competing standards for a long time Authorization semantics and chargeback liability won't unify within a decade; cross-ecosystem recognition stays at the level of bilateral agreements. <i>Falsified if: a single authorization standard is jointly adopted by the major payment networks and major platforms.</i>	2027 — 2035 Medium confidence
5	Value splits three ways: execution, facts and governance No single AI operating system for finance emerges; each layer has incumbents, and the governance layer forms last and is the most underrated. <i>Falsified if: one player firmly holds both execution and facts, and governance is absorbed as one of its features.</i>	2028 — 2035 Medium confidence
6	Fully autonomous finance won't be mainstream before 2035 Unreviewed lending, advice and trade execution will keep limits and scope boundaries for a long time, with the boundaries adjusted as incident rates change. <i>Falsified if: any major market lets autonomous lending or trade execution without limits become routine business.</i>	2030 — 2035 High confidence

The six aren't independent of one another. **Bet 3 is the linchpin**: once mandatory incident disclosure happens, actuaries have data, the economics of bet 2 work, and the procurement clauses of bet 1 are forced to accelerate. Conversely, if disclosure regimes are slow to appear, bets 2 and 1 slip significantly and bet 6 becomes even safer.

Bets 4 and 5 form another pair: competing standards mean no one can monopolize authorization semantics, which is exactly what keeps the three layers from collapsing into one. **If a single standard is ever widely adopted, bet 5 needs rethinking too** — because whoever sets the standard will use it to expand up and down the stack.

The linchpin is bet 3

Mandatory disclosure → actuarial data → insurance → L3 economics work. Watch this one ahead of the other five.

Linked falsification

If bet 4 is falsified, rethink bet 5 too: the standard-setter will expand up and down the stack.

5.2 If you're building products in 2026

Translated into action, the six bets mean different things depending on where you sit.

If you're founding a startup. Don't build a general-purpose financial assistant. Pick an area where errors are observable and reversible, finish all five components — limits, circuit breakers, dual tracks, review triggers and rollback — and then find three institutions willing to share your first incident with you. Your moat won't come from the model. It will come from the fact that those three institutions were willing to hand you the permissions.

If you run products at a large institution. Your scarcest resource isn't budget; it's **an attributable baseline**. Before any AI project, spend two months building a human baseline and a gold-standard evaluation set — without them, three years from now you still won't be able to say whether the investment was worth it. And treat governance capability as part of the product roadmap, not as compliance's afterthought.

If you work in investment or strategy. Use "which control rights does this company hold?" as your first screen and "will the next generation of models erase its edge?" as your second. Demand faster returns from pure judgment-layer companies, because they're standing on the side where costs are collapsing.

If you work in regulation or policy. The most valuable step, in this book's view, is to push for mandatory incident disclosure and the sharing of de-identified failure modes. It solves three problems at once: institutions learn from one another, insurance becomes priceable, and concentration risk becomes visible.

What all four have in common: **none of them needs to wait for technology to advance another step**. Every recommendation above can start today, and each one gets more expensive over time while its payoff jumps when liability shifts. It's the classic "cheaper if done early" structure — and most organizations will wait until they have no choice.

Closing

The whole argument of this book fits in one sentence: **the next decade of fintech won't be decided by whose model is strongest, but by who is allowed to move money when nobody is watching.**

That variable is close to zero today, so nobody models it and nobody prices it. But it won't stay at zero forever — because nothing needed to move it off zero is out of reach. Limits can be designed, circuit breakers built, audits recorded, liability priced and insurance underwritten. **They just haven't been systematically finished yet.**

Whoever finishes them first will be standing on the allowed side when the next liability shift comes. And when that moment arrives, the market will suddenly discover it has been pricing the wrong thing all along.

Founders

Your moat isn't the model; it's the fact that institutions are willing to hand you permissions.

Product managers at large institutions

Your scarcest resource isn't budget but an attributable baseline. Without one, three years on you still can't prove anything.

Investment and strategy

First screen: which control rights does it hold?
Second screen: will the next generation of models erase its edge?

Policy

Mandatory incident disclosure solves three problems in one step: shared learning, priceable insurance, visible concentration.

Appendix A Tracking list and definitions

Table A.1 · Ten signals to track each quarter

#	Signal	Where to look	What it means once it appears
1	Standalone governance clauses appear in tenders	Public tender notices; master service agreement templates	The access shake-out has begun; bet 1 pays off
2	A standalone insurance line for AI decision errors	Insurance product filings; industry announcements	The economics of L2 → L3 work
3	Mandatory AI incident reporting or failure-mode sharing	Regulatory notices; self-regulatory rules	The insurance window is about to open
4	Agent-payment authorization and chargeback rules written down for the first time	Payment network rulebooks; platform developer agreements	The standards war enters its substantive phase
5	Separate revenue, paid penetration and renewal rates for AI modules disclosed	Annual and quarterly reports; investor calls	Commercial proof turns from narrative into fact
6	Critical third parties brought under direct oversight	Regulatory designations; rule amendments	Concentration risk is formally priced
7	Public domain eval sets cited in procurement documents	Technical requirements in tenders; industry standards	Evaluation assets become influence
8	The first public dispute or ruling over an agent exceeding its authority	Court records; regulatory enforcement actions	Liability allocation starts to converge
9	Production incident rates, model drift or vendor concentration rise markedly	Regulatory reports; industry surveys	The whole timeline may slip
10	Outcome-based pricing moves from marketing slogan to auditable contract clause	Contract templates; customer case studies	The pricing model has completed its migration

Definitions

Trusted-amount ceiling. The maximum amount of money movement a system is allowed to initiate without per-transaction human review. The book's core variable, measured separately for each area.

Automation depth L0–L4. A five-level framework defined by whether a system can reach conclusions alone, act alone, and who bears the consequences. See Section 1.1.

System of record. The authoritative home of a class of business facts (ledgers, positions, filings). Replacing it means migrating historical data and process configuration.

Continuous outcome labels. Real outcomes that flow back automatically with the business (was it charged back, did it default, was it accepted), as opposed to static corpora bought or labelled once.

Governance stack. Evaluation sets, logging, permissions, red-teaming, fallback and vendor exit mechanisms, taken together. In this book's view, it is turning from a cost item into an entry requirement.

Delegation chain. The chain of authorization user → business → agent → action. What identity verification has to check in the agent era.

How the ceiling is measured

The trusted-amount ceiling is set per area; there is no single company-wide number. Be suspicious of anyone who claims one.

How it differs from common terms

This book doesn't use "automation rate," because it lumps L0 report generation together with L2 automatic execution.

Appendix B Sources

Evidence hierarchy: regulatory and legal documents and audited annual reports come first; official product pages confirm features and self-reported scale; academic and international-organization reports inform judgments about mechanisms. Efficiency, transaction and user figures disclosed by companies are not treated as third-party verified. Market spending forecasts indicate direction only and are never a basis for valuation.

The projections in this book

Any judgment without a cited source is the author's projection, with its triggers and falsification conditions stated in the text.

#	Source	Type	Used for
[1]	Mao Zedong, <i>Oppose Book Worship</i> , 1930	Methodology	Research method
[2]	Mao Zedong, <i>Preface and Postscript to "Rural Surveys"</i> , 1941	Methodology	Research method
[3]	Mao Zedong, <i>On Practice</i> , 1937	Methodology	Method of judgment
[4]	BoE / FCA, <i>Artificial Intelligence in UK Financial Services</i> , 2024 (118 firms)	Regulatory survey	Adoption and share of autonomous decisions
[5]	World Economic Forum, <i>Artificial Intelligence in Financial Services</i> , 2025	International org.	Spending scale and direction
[6]	BIS, <i>Intelligent Financial System: How AI Is Transforming Finance</i> , 2024	International org.	Industry structure
[7]	Financial Stability Board, <i>The Financial Stability Implications of Artificial Intelligence</i> , 2024	International org.	Systemic risk and herding
[8]	FSB, <i>Sound Practices for Responsible Adoption of AI</i> — consultation, 2026	International org.	Governance practice
[9]	China Academy of Information and Communications Technology (CAICT), <i>Research Report on Digital Finance Innovation and Development (2025)</i> , 2026	Research institute	State of China's industry
[10]	National Financial Regulatory Administration, <i>Guiding Opinions on the Safe Development and Application of AI in the Banking and Insurance Sectors</i> , 18 June 2026	Regulatory document	China's governance logic
[11]	U.S. Treasury, <i>Financial Services AI RMF + AI Lexicon</i> , 19 February 2026 (230 control objectives; non-binding)	Regulatory framework	US governance logic
[12]	European Commission, <i>AI Act — Regulatory Framework and Timeline</i> , 2026	Legislation	EU risk tiers
[13]	EUR-Lex, <i>Digital Operational Resilience Act (DORA)</i> , applicable since 2025	Legislation	Third parties and resilience
[14]	Ant Group, <i>Product and Technology Updates at the 2025 World Artificial Intelligence Conference</i> , 2025	Company disclosure	Direction of agent payments
[15]	Ant Group, <i>2024 Sustainability Report Highlights</i> , 2025	Company disclosure	Global reach
[16]	Stripe, <i>2025 Annual Letter</i> , 2026	Company disclosure	Payment volume and agentic commerce
[17]	Stripe, <i>2025 Annual Letter</i> : adaptive acceptance recovered about \$6B in false declines in 2024	Company disclosure	False-decline recovery
[18]	Stripe, Radar product page, September 2026: 70T+ data points; 32% average fraud reduction	Official product page	Scale of network data
[19]	Intuit, FY2026 full-year results, 25 August 2026: revenue \$21.4B (+14%)	Company financials	Revenue and business mix
[20]	Intuit, <i>Virtual Team of AI Agents for QuickBooks</i> , 2025	Official product page	Agents and expert review
[21]	Bloomberg Professional, <i>AI on Bloomberg / ASKB</i> , accessed September 2026	Official product page	Data and workflow
[22]	Wu et al., <i>BloombergGPT: A Large Language Model for Finance</i> , arXiv, 2023	Academic	Early view of domain models
[23]	Hithink RoyalFlush (Tonghuashun), <i>2025 Annual Report</i> , 2026: revenue ¥6.029B; net profit attributable to shareholders ¥3.205B	Audited annual report	China research and eval assets
[24]	Ant Group, corporate website: AI payments and group business facts, accessed September 2026	Official product page	Payments MCP and AI wallet

Appendix C Method, discount rules and research limits

Method

The approach: first use regulatory documents, audited annual reports and international-organization reports to establish what has already happened; then build conditional projections on those facts, giving each projection observable triggers and falsification conditions. Claims that can't be falsified are, as far as possible, left out.

The book does **not** forecast model capability or rely on any assumption about model performance — it rests precisely on the premise that model capability keeps commoditizing. If that premise falls, the scissors-gap argument in Chapter 3a is the first to fail.

Data verification statement

Every public figure cited was checked against its primary source on **11 September 2026**: original regulatory surveys and legislation, company financial statements and results announcements, and official product pages. Nine statements were corrected as a result before the first edition was finalized, three of them substantive errors; the corrections are preserved in the repository's commit history.

That doesn't mean the book is now error-free. Four caveats remain. First, **company-reported figures cannot be independently verified**; the book uses them to judge direction, never to support a conclusion. Second, figures on official product pages change over time; the text reflects them as of the access date. Third, the author is not a finance professional and may misread regulatory documents. Fourth, anything marked "research judgment" or appearing in a projection chapter is the author's inference, not a statement of fact.

If you find an error, please raise it in the repository; corrections will be recorded in the version history. Research that circulates with known errors is more dangerous than research that admits it may be wrong.

Why publish the list of errors

Only when readers know what changed do they know what to re-check. A hidden correction leaves everyone who cited the old version still wrong.

Why state the number of errors

"Nine corrections, three of them substantive" is more useful than a vague "the data may be inaccurate" — the first can be checked; the second is just a disclaimer.

Table C.1 · Three substantive corrections made before the first edition was finalized

Earlier claim	Verification result	Current wording
Regulated activities rank 9th–21st of 21 in AI penetration	No such ranking exists in the 2024 BoE/FCA report, which does not rank 21 business areas	Replaced with the report's actual data: only 2% of use cases are fully autonomous
Radar recovered \$6B of declined transactions and cut user dispute rates by 17%	The \$6B belongs to adaptive acceptance , not Radar, and is for 2024, up 60% year on year; the 17% appears in no public source	Each figure attributed as the company reports it; Radar cited for its official "32% average fraud reduction"
Intuit saves customers up to 12 hours a month and gets them paid 5 days faster	No source found in public disclosures	Replaced with FY2026 disclosures: 3M+ customers using AI agents, repeat usage >85%

Six further corrections concerned precision and naming: Intuit's revenue basis, the name and date of the US regulatory document, the full title and publication date of China's guiding opinions, Alipay+ coverage figures, Bloomberg Terminal user numbers, and the number of firms surveyed.

Evidence-discount rules

Company-reported efficiency gains indicate direction only; unaudited revenue and user numbers never enter structural conclusions; media valuations and funding rumors are not used at all; the number of product launches doesn't count as commercial proof; features still in beta count toward product capability but not commercial validation; "number of institutions covered" does not equal paid penetration and is always flagged separately when cited.

Research limits

This book is not an industry directory. It makes no valuation judgments about private companies and does not constitute investment advice. The five companies discussed illustrate different types of industry control point; they are not the only representatives of their fields. In-house bank development, insurtech, regtech and foundation-model makers appear in the value-chain discussion but are not analyzed separately.

Every statement about the period after 2026 is a conditional projection. Readers should revise their judgments quarterly as new facts arrive, particularly the ten signals in Appendix A. **If a projection's falsification condition appears first, the right response is to overturn it, not to explain it away.**

Three known blind spots

1. Insurance is barely discussed. AI in insurance has its own structure (underwriting, claims, actuarial regulation) whose logic differs markedly from banking and payments. Including it would blunt the argument, but its absence is a real gap in coverage.

2. A gradual geopolitical environment is assumed. Major technology export controls or a decoupling of financial infrastructure would require the cross-border projections to be rewritten entirely.

3. The perspective is mainly institutional. Whether consumers are willing to let agents spend money on their behalf is treated as exogenous. This may be the biggest untested assumption in the book.

Writing principle

Leave out claims that can't be falsified. This is the main difference between this book and most industry forecasts.

The most fragile premise

That model capability keeps commoditizing. If one company builds a durable lead in finance-specific models, the scissors-gap argument fails first.

How to update

Check against the ten signals in Appendix A each quarter. Adjust judgments only when a signal appears, never just because time has passed.

Errata

Please report errors in the repository. Corrections carry version numbers and old versions are never deleted — so anyone who cited an older version knows what they cited.

ABOUT THIS BOOK

The Money AI Is Allowed to Move: Fintech's Next Decade is an independent industry projection. It sets out to reframe a question usually told as a technology race as a question of how authority, liability and standards are allocated. All company facts come from public disclosures; no non-public information is used, and nothing here constitutes investment advice.

Author Zhihua Zou. The thesis, framework, judgments and conclusions are the author's; structured drafting, research organization and typesetting were done with Claude (Anthropic), and every fact and projection was checked by the author line by line.

Edition English edition, September 2026, translated from the Chinese first edition 《被允许动的钱：金融科技的下一个十年》 · Research current to 10 September 2026

Repository github.com/joshuazou-web/money-ai-is-allowed-to-move

Copyright © 2026 Zhihua Zou. All rights reserved. Licensed under **CC BY-NC-ND 4.0**: you may freely share, quote and redistribute it with full attribution and a link to the source; no commercial use; no distribution of adapted versions. The full writing process is preserved in the commit history of the repository above.